DIGITALISERINGSDIREKTORATET

PROSJEKT: REFERANSEIMPLEMENTASJON AV EU-WALLET

Digdir sommercamp - sommeren 2024

Seksjonsleder:
Jørn Stenehjem

Antall sider: 21

15.07.2024

Digdir sommercamp 2024

Kleiven, Oline Flatabø. Friis, Karsten Selmer. Eikeland, Siri. Neset, Daniel. Langbakk, Solveig. Kvamme, Brage Halvorsen. Bråtveit, Elise Strand. Løwer, Magnus

11. september 2024

Sammendrag

Denne rapporten omhandler utviklingen av vår egen referanseimplementasjon av issuer og verifier for EU Wallet, en digital identitetsløsning initiert av EU-kommisjonen, og MATTR wallet, som er en privat lommebokløsning. Vårt mål er å gjøre det mulig for brukere å utstede og verifisere digitale bevis på en sikker måte. Vi forklarer nøkkelbegreper, beskriver utviklingen av de ulike komponentene, og diskuterer resultatene samt potensielle forbedringsområder.

EU Wallet er en digital plattform som gir innbyggerne i EU en sikker og brukervennlig måte å håndtere sin digitale identitet på. Plattformen lar brukerne lagre, administrere og dele personlige data og dokumenter på en trygg måte. Ved å bruke ulike sikkerhetsprotokoller og kryptografi, sikrer EU Wallet at dataene forblir beskyttet mot uautorisert tilgang og misbruk.

Rapporten gir en gjennomgang av hovedtrekkene, funksjonene og fordelene med EU Wallet, sammen med vår egen implementasjon av denne digitale lommeboken og løsninger for issuer og verifier. Vi utforsker de teknologiske og sikkerhetsmessige aspektene ved løsningene, og diskutere hvordan vi kan tilpasse og optimalisere vår versjon for å møte de spesifikke behovene til våre brukere. Gjennom denne prosessen håper vi å bidra til en bedre forståelse av digitale identitetsløsninger og deres potensial for å forbedre digital sikkerhet og effektivitet i samfunnet.

Forord

Formålet med dette prosjektet har vært å videreutvikle kompetansen vi har opparbeidet gjennom studier og arbeidserfaring, spesielt innenfor Digdirs rammeverk. Underveis har vi ikke bare fått en bedre forståelse av sentrale sikkerhetsbegreper, men vi har også blitt tryggere å implementere og håndtere digitale identiteter på en sikker måte. Vi ser på dette som avgjørende for å sikre trygge og pålitelige tjenester. Vi setter stor pris på all hjelpen vi har fått av våre kollegaer for deres verdifulle støtte og oppmuntring. Vi har hatt en spennende og lærerik sommer hos Digdir, og vi ser fram til å bygge videre på det vi har lært.

Startdato for rapportskriving: 15.07.2024
Sted: Digdir, Leikanger.

Medlemmer: Kleiven, Oline Flatabø. Friis, Karsten Selmer. Eikeland, Siri. Neset, Daniel. Langbakk, Solveig. Kvamme, Brage Halvorsen. Bråtveit, Elise Strand. Løwer, Magnus

---

Lenker til de tre Github-repositoriene:

Mattr Issuer
Mattr og EU Verifier
Vår egen implementasjon av Issuer

Forkortelser

API Application Programming Interface. 1, 3, 7, 8, 10–12, 16–18

CBOR Concise Binary Object Representation. 4, 12, 17, 18

COSE Cbor Object Signing and Encryption. 4, 8, 9, 17

DID Desentralisert Identitet. 2, 7, 8

EUDI EU Digital Identity. 4

EUDIW EU Digital Identity Wallet. 8, 9, 16, 17

IDP Identity Provider. 9

JOSE Json Object Signing and Encryption. 4

JSON JavaScript Object Notation. 4, 18

JWT JSON Web Token. 9, 17

MDOC Mobile document. 4

OID4VCI OpenID for Verifiable Credential Issuance. 8, 9, 16

OIDC OpenID Connect. 2

PKI Public Key Infrastructure. 3

PoC Proof of Concept. 16

RP Relying Party. 4

Innhold

Sammendrag i

Forord ii

Forkortelser iii

1 Bakgrunn 1

1.1 Målsetninger . . . 1

2 Teori 2

2.1 Desentralisert ID . . . 2
2.2 Issuer (Utsteder) . . . 2
2.3 Verifier (Bekrefter) . . . 2
2.4 OAuth 2 . . . 2
2.5 OpenID Connect 1.0 . . . 2
2.6 ID-porten . . . 2
2.7 Protokoll . . . 2
2.8 API . . . 3
2.9 Altinn autorisasjon . . . 3
2.10 Ansattporten . . . 3
2.11 PKI . . . 3
2.11.1 Digitale sertifikater . . . 3
2.11.2 Sertifikatautoritet . . . 3
2.12 Bevis . . . 3
2.13 Vergemål . . . 3
2.14 COSE og CBOR . . . 4
2.15 COSE parsing . . . 4

3 Metode 5

3.1 Verktøy og teknologier . . . 5
3.2 Implementeringsprosess . . . 5
3.2.1 Planlegging . . . 5
3.2.2 Utvikling . . . 5
3.2.3 Testing . . . 5
3.3 Teamdynamikk . . . 5
3.3.1 Morgenøkter . . . 5

4 Resultater 6

4.1 Implementering av design . . . 6
4.1.1 Prinsipp 1: Like muligheter for bruk . . . 6

4.1.2 Prinsipp 2: Fleksibel i bruk . . . 6
4.1.3 Prinsipp 3: Enkel og intuitiv bruk . . . 6
4.1.4 Prinsipp 4: Forståelig informasjon . . . 6
4.2 Vergemål . . . 7
4.3 MATTR Issuer . . . 7
4.3.1 Endepunkter for issuer . . . 7
4.4 EU Issuer . . . 8
4.4.1 Endepunkter . . . 9
4.5 MATTR Verifier . . . 10
4.5.1 Endepunkter for verifier . . . 10
4.6 EU Verifier . . . 11
4.6.1 Endepunkter for verifier . . . 12

5 Diskusjon **13**
5.1 Vergemålsdiskusjon . . . 13
5.1.1 Flyt 1 . . . 13
5.1.2 Flyt 2 . . . 14
5.1.3 Flyt 3 . . . 14
5.1.4 Flytkonklusjon . . . 15
5.1.5 Deling av informasjon . . . 15
5.1.6 Autentisering . . . 16
5.2 Erfaringer med Issuer . . . 16
5.2.1 EUs referanseimplementasjoner vs. Mattr . . . 16
5.2.2 Ansattporten data . . . 17
5.2.3 EU mDOC CBOR formatter . . . 17
5.3 Erfaringer med Verifier . . . 17

6 Konklusjon **19**
6.1 Oppsummering . . . 19
6.2 Fremtidige anbefalinger . . . 19
6.2.1 Optimalisering og videre utvikling . . . 19
6.2.2 Tilgjengelighet for Blinde og Svaksynte . . . 19
6.2.3 Anbefalte tiltak for videre utvikling . . . 19
6.3 Ting som har fungert bra . . . 20

1 Bakgrunn

EU lommebok er en digital løsning som er utviklet av EU-kommisjonen som en del av initiativet for digital identitet. Denne løsningen er designet for å gi innbyggere i EU en sikker og praktisk måte å identifisere seg digitalt på, samtidig som de kan lagre og dele data på en trygg måte. Ved å samle ulike typer personlig informasjon og dokumenter i én digital plattform, gir EU lommebok brukerne full kontroll over sine data, noe som gir økt sikkerhet i en digital hverdag.

Initiativet for digital identitet er en del av EUs strategi for å øke digitaliseringen, med mål om å styrke bruken av digitale tjenester i samfunnet. Gjennom EU lommebok ønsker EU-kommisjonen å gi innbyggerne en effektiv måte å håndtere digitale identiteter på. Løsningen inkluderer også støtte for desentralisert ID, som gir brukerne enda større kontroll over sine egne identitetsdata, uten å være avhengig av en sentral autoritet for å bekrefte identiteten.

1.1 Målsetninger

Målet vårt i denne rapporten er å utforske og implementere en issuer og verifier ved hjelp av MATTR sitt Application Programming Interface (API), samt utvikle både en issuer og en verifier som kan kommunisere med EUs lommebok. Basert på det vi har lært gjennom sommercampen her på Digitaliseringsdirektoratet, vil vi undersøke hvordan vi kan tilpasse og forbedre disse løsningene for å møte våre spesifikke behov og krav, samtidig som vi opprettholder høy standard for sikkerhet og personvern.

2 Teori

2.1 Desentralisert ID

Desentralisert Identitet (DID) er en måte å oppnå digital identitet uten å være avhengig av en sentral myndighet. I stedet for å bruke tradisjonelle sentraliserte systemer, som for eksempel nasjonale identitetsregistre, bruker DID desentraliserte nettverk, ofte basert på blokkjedeteknologi. Dette gir brukere full kontroll over sine egne identiteter og data, noe som øker både personvern og sikkerhet (Sporny mfl., 2022).

2.2 Issuer (Utsteder)

En issuer, eller utsteder, er en enhet (person eller organisasjon) som lager og utsteder digitale bevis. Når en issuer utsteder et digitalt bevis, signerer den det kryptografisk, noe som gjør det mulig for andre å verifisere at beviset er ekte, og uendret, uten å måtte kontakte utstederen direkte. (IDManagement, 2024).

2.3 Verifier (Bekrefter)

En verifier, eller bekrefter, er en enhet som mottar og verifiserer de digitale bevisene. Når en bruker presenterer et digitalt bevis til en verifier, kan verifieren sjekke om beviset er ekte ved å validere den kryptografiske signaturen som ble brukt av issuer. Dette gjør det mulig å bekrefte identiteten eller kvalifikasjonene til brukeren uten å måtte kontakte issuer direkte. (Crane, 2020).

2.4 OAuth 2

OAuth 2 er en åpen standard for tilgangsdelegasjon som brukes for å gi nettsider eller apper begrenset tilgang til brukerens data på en annen tjeneste, uten å dele brukerens påloggingsinformasjon. Det gir en sikker og standardisert måte å gi tilgang til ressurser på tvers av forskjellige tjenester (Bremer, 2024).

2.5 OpenID Connect 1.0

OpenID Connect (OIDC) er et identitetslag bygget på toppen av OAuth 2.0. Det legger til funksjoner som gjør det mulig for apper å bekrefte identiteten til brukere på en sikker måte og få grunnleggende profilinformasjon om brukeren. Dette gjør OIDC ideelt for autentisering, mens OAuth 2.0 primært er for autorisasjon (auth0, 2024).

2.6 ID-porten

ID-porten er en felles innloggingsløsning for offentlige tjenester i Norge, som administreres av Digitaliseringsdirektoratet. Den gir brukere enkel og sikker tilgang til en rekke offentlige tjenester ved hjelp av én felles innloggingsmetode. ID-porten støtter flere elektroniske ID-er (eID) som BankID og MinID (eidDifi, 2024).

2.7 Protokoll

En protokoll refererer til et sett med regler og standarder som gjør det mulig for ulike enheter å kommunisere med hverandre. Protokoller definerer hvordan data formateres, overføres og behandles, og de sikrer at enheter kan forstå hverandre til tross for potensielle forskjeller i maskinvare og programvare (Cloudfare, 2024).

2.8 API

Et API er et sett med regler og protokoller som tillater forskjellige programvareapplikasjoner å kommunisere med hverandre. APIer definerer metoder og datatyper som en applikasjon kan bruke for å be om tjenester fra et operativsystem, programvarebibliotek, eller en annen applikasjon (Goodwin, 2024).

2.9 Altinn autorisasjon

Altinn autorisasjon er et system som gjør det mulig å kontrollere og delegere tilgang til ulike tjenester og data innen Altinn-plattformen. Dette er spesielt nyttig for bedrifter og organisasjoner som trenger å gi spesifikke ansatte eller eksterne parter tilgang til bestemte oppgaver eller informasjon (Altinn, 2017).

2.10 Ansattporten

Ansattporten er en digital plattform utviklet for å gi ansatte i offentlige virksomheter i Norge sikker og enkel tilgang til ulike interne og eksterne tjenester. Den fungerer som en inngangsport til en rekke administrative systemer og tjenester som ansatte trenger i sin arbeidshverdag. Ansattporten er en viktig del av digitaliseringen av offentlig sektor, og den bidrar til å effektivisere arbeidsprosesser, forbedre kommunikasjonen og øke sikkerheten ved tilgang til sensitive data (Digdir, 2024b).

2.11 PKI

Public Key Infrastructure (PKI) er et rammeverk for å administrere digitale sertifikater og offentlig-nøkkel kryptering. Det gjør det mulig å ta i bruk sikre elektroniske overføringer ved å bruke en kombinasjon av offentlig og privat nøkkelpar. PKI brukes for å autentisere identiteter, sikre kommunikasjon, og sikre integriteten til data (Bremer, 2024).

- **2.11.1 Digitale sertifikater**

  Et digitalt sertifikat er et elektronisk dokument med formål om å bevise eierskap til en offentlig nøkkel. De inneholder den offentlige nøkkelen samt eierens identitet. Sertifikatene utstedes av en sertifikatsautoritet. (Bremer, 2024).

- **2.11.2 Sertifikatautoritet**

  En sertifikatautoritet er en organisasjon som lager og gir ut digitale sertifikater for å bekrefte eller avkrefte informasjon. Dette kan eksempelvis være å bekrefte at en person er den den utgir seg for å være på internett. Sertifikatautoritet kan også bekrefte eller avkrefte om en nettside tilhører den organisasjonen de utgir seg for å tilhøre. Dette er essensielt for å opprettholde sikkerheten (Bremer, 2024).

2.12 Bevis

Et bevis er en digital representasjon som brukes for å bekrefte identiteten til en person, enhet, eller organisasjon. Det fungerer som en elektronisk attest som inneholder viktig informasjon om den identifiserte parten. Denne informasjonen kan være avgjørende for å gi tilgang til spesifikke tjenester eller ressurser (Bremer, 2024).

2.13 Vergemål

Personer som ikke kan ta hånd om sine egne interesser grunnet sykdom, skade eller funksjonsnedsetting kan få hjelp av en verge. Ett vergemål er en frivillig ordning, som er tilpasset ønskene og behovene til den som

er verge. Verge oppnevnes av statsforvalteren, og det er hen som også har oppfølgning. Det er sivilrettsforvaltningen som er sentral vergemålsmyndighet, som betyr at de har ansvar for å saksbehandle klagesaker ved klage på vedtak fra statsforvalteren samt å lage retningslinjer for lik praktisering av lovbestemmelsene (Sivilrettsforvaltningen, 2024).

Digitaliseringsdirektoratet arbeider med en løsningsarkitektur for håndtering av vergemålsdata. De foreslår ett alternativ der to nye felt introduseres, og PID fjernes. Feltene skal respektivt inneholde fødselsnummer til verge og vergehaver (Binningsbø, 2024).

2.14 COSE og CBOR

Concise Binary Object Representation (CBOR) er et dataformat designet for å være kompakt, både når det gjelder dataens lagringsstørrelse og meldingsstørrelsen ved overføring. Når man bruker CBOR for meldinger, kan man bruke Cbor Object Signing and Encryption (COSE) for å kryptere og signere dataen. CBOR utvider JavaScript Object Notation (JSON) sin datamodell ved å blant annet tillate binær data. COSE er en protokoll som beskriver hvordan man lager og prosesserer signaturer, autentiseringsmeldinger og kryptering ved bruk av CBOR for serialisering. COSE har mange av egenskapene som Json Object Signing and Encryption (JOSE) har, men har i tillegg egne egenskaper (Shaad & Cellars, 2024).

2.15 COSE parsing

For å skrive en melding om til COSE format har vi brukt Marco, 2024 sin implementasjon, som er skrevet i Python. Marco, 2024 inkluderer en parser (leser og analyserer data) og writer (genererer og skriver ut data). Per 2. august 2024 støtter repoet bruksområder rundt Mobile document (MDOC) CBOR for credential type 1 og mDL. Denne implementasjonen er en fork (kopi av et tidligere prosjekt) ledet av en italiensk utvikler fra Team Digitale Italia, en enhtet som kan sammenlignes med Digdir i Norge. Team Digitale har utviklet en tjeneste som kommuniserer med EU lommebok, samt en Python-toolchain som hjelper med å implementere en EU Digital Identity (EUDI) lommebok Relying Party (RP) i tråd med italienske implmenteringskrav. Denne toolchainen benyttes av både EU-issueren og i Italia sin lommebok-implementasjon (Marco mfl., 2024).

3 Metode

I denne delen beskriver vi hvordan vi implementerte vår versjon av EU lommebok, samt hvilke verktøy og metoder vi benyttet. Hovedverktøyene var Java, Spring Boot, Git, Python, og Fly.io.

Vi fulgte en strukturert tilnærming med fokus på nøye planlegging, målrettet utvikling og omfattende testing for å sikre at løsningen oppfylte funksjonelle krav og sikkerhetsstandarder.

3.1 Verktøy og teknologier

Vi valgte å bruke Java som programmeringsspråk, kombinert med Maven for bygging og avhengighetshåndtering, og Spring Boot som rammeverk. Git ble benyttet for å muliggjøre parallelt arbeid og enkel sporing av endringer. For implementeringen av issuer til EU lommebok brukte vi Python, basert på EUs referanseimplementasjon (Pereira mfl., 2024). Hosting ble utført på Fly.io, som ga oss en enkel og skalerbar løsning for distribusjon og administrasjon av tjenestene.

3.2 Implementeringsprosess

3.2.1 Planlegging

Vi brukte den første uken til å lese oss grundig opp på EU lommebok sin referanseimplementasjon, samt andre begreper som er beskrevet i teoridelen av prosjektet. Dette var viktig for at vi kunne få mer forståelse til å utvikle vår egen referanseimplementasjon. Denne forberedelsen bidro til en mer strukturert og målrettet utviklingsprosess, og sørget for at vi kunne arbeide mer effektivt gjennom resten av prosjektet.

3.2.2 Utvikling

Vi delte teamet inn i to grupper: Issuer og Verifier, for å fordele arbeidet bedre og fokusere på spesifikke deler av prosjektet. Dette ga hvert medlem av teamet muligheten til å fordype seg i sitt eget ansvarsområde. Vi følte at vi raskt kunne finne og løse problemer ved å jobbe parallelt med de ulike gruppene. Denne måten å jobbe på gjorde dermed utviklingsprosessen mer effektiv og ga oss bedre oversikt over prosjektet som helhet.

3.2.3 Testing

Vi benyttet oss hovedsakelig av enhetstesting (unit testing) for å teste ulike funksjoner og metoder i koden vår. Dette ble gjort for å sikre at hver enkelt del av koden fungerte som forventet, og for å løse opp i eventuelle feil eller mangler tidlig i utviklingsprosessen. Ved å teste mindre komponenter uten å teste hele systemet kunne vi enklere identifisere og rette opp i problemer, noe som bidro til å opprettholde en høy kvalitet og lesbarhet i koden vår.

3.3 Teamdynamikk

For at vi skulle lykkes i å utvikle vårt prosjekt, la vi stor vekt på å skape et miljø hvor kommunikasjon og samarbeid var i fokus. Ved å delegere ulike oppgaver og ha regelmessige møter, klarte vi å arbeide effektivt gjennom prosjektet. Dette bidro til å styrke samholdet i teamet vårt. Vi hadde ulike strukturer og rutiner på plass for å sikre at alle teammedlemmene var involvert og informert.

3.3.1 Morgenøkter

Hver morgen startet vi dagen med standup-møter, basert på Scrum. Her diskuterte vi status, identifiserte hindringer og planla dagens oppgaver. Dette ga oss god oversikt og forbedret samarbeidet. Møtene ble holdt korte for å maksimere tiden til arbeid.

4 Resultater

For å gi en god og strukturert oversikt over prosjektet vi har jobbet med, vil vi gjennomgå de spesifikke områdene der ulike funksjoner har blitt implementert og testet. Hver seksjon fokuserer på ulike ting, fra designimplementering til utvikling av verktøy som sikrer tilgjengelighet, brukervennlighet, og integrasjon med digitale identitetsløsninger.

4.1 Implementering av design

Design er avgjørende for at alle mennesker skal kunne forstå og bruke digitale applikasjoner. For å sikre tilgjengelighet for alle, inkludert de med nedsatte funksjonsevner som blindhet eller døvhet, er universell utforming essensielt. Vi har fokusert på å forbedre tilgjengeligheten i EU sin digitale lommebok, særlig for issuer og verifier, ved å implementere de fire første prinsippene for universell utforming. På grunn av tidsbegrensninger har vi ikke inkludert de tre siste prinsippene.

Det er kritisk at EU sin digitale lommebok er designet for å være tilgjengelig for alle brukere, uansett funksjonsevne, for å oppfylle EUs krav om en universell digital identitetslommebok. Ved å følge beste praksis og ta hensyn til brukernes behov, sikrer vi en inkluderende og brukervennlig løsning som kan benyttes av alle innbyggere, og dermed oppfylle EU sitt krav for tilgjengelighet.

4.1.1 Prinsipp 1: Like muligheter for bruk

Utformingen skal være brukbar og tilgjengelig for personer med ulike ferdighetsnivåer. Dette prinsippet har vært viktig for å kunne sikre at alle brukere, uansett teknisk kompetanse eller funksjonsevne, kan benytte seg av systemet på en enkel og effektiv måte. Vi har forsøkt å sikre at grensesnittet er intuitivt, og at alle funksjoner er lett tilgjengelige, uavhengig av brukerens forutsetninger.

4.1.2 Prinsipp 2: Fleksibel i bruk

HTML-filene i Spring Boot-prosjektet vårt er designet for å være tilpasset ulike typer skjermlesere takket være semantiske HTML-elementer og ARIA-attributter. Applikasjonen fungerer bra på både telefon, nettbrett og datamaskinen, noe som øker tilgjengeligheten. Vi testet prosjektet vårt i Google Chrome, der vi kunne se hvordan det ville se ut på forskjellige skjermlesere, og derfor enkelt kunne gjøre nødvendige justeringer. Skriftstørrelser og plassering av containere er eksempler på slike endringer. Vi implementerte også darkmode, som lar brukerene bytte mellom lys og mørk modus, som forbedrer brukervennligheten.

4.1.3 Prinsipp 3: Enkel og intuitiv bruk

Vi har strukturert HTML-sidene med `<nav>`, `<section>`, og `<footer>` for å organisere innholdet effektivt. I CSS har vi fokusert på responsivt design for å sikre at applikasjonen ser bra ut på alle enheter. Vi har naturligvis unngått fargekombinasjoner som rød og grønn, som kan være problematiske for personer med fargesynsproblemer. Fargevalgene er inspirert fra Digdir sin Profilveileder for å forbedre lesbarheten. (Digdir, 2024a). Vi har lagt frontenden inn i React.

Vi har gjort det enkelt å bytte mellom dark-mode og light-mode. Ved å klikke på knappen med klassen dark-mode-toggle kan brukerne enkelt skifte mellom de to modusene. Valgt tema lagres automatisk i localStorage, slik at det huskes til neste gang brukeren besøker siden. Dette gir brukerne mulighet til å tilpasse nettsidens utseende etter eget ønske, noe som forbedrer brukeropplevelsen. Videre har vi sett på mulighetene for opplesning ved aktivering av Narrator (`Windows-tast + Ctrl + Enter`). Dette har derimot ikke vårt fokus, så derfor heller noe som kunne blitt videreutviklet mye mer, og sett nærmere på.

4.1.4 Prinsipp 4: Forståelig informasjon

For å forbedre forståeligheten har vi tydeliggjort knappetekster ved å bruke aria-label, som for eksempel ”Aktiver dark mode for bedre lesbarhet”. Dette er nyttig for brukere som er avhengige av skjermlesere. Vi

har også sikret god kontrast og riktig skriftstørrelse, som nevnt i prinsipp 3, for å sikre lesbarhet. Videre har vi spesifisert språket i HTML-dokumentene ved å bruke `lang="no"` for norsk og `lang="en"` for engelsk, noe som forbedrer tilgjengeligheten for skjermleserbrukere.

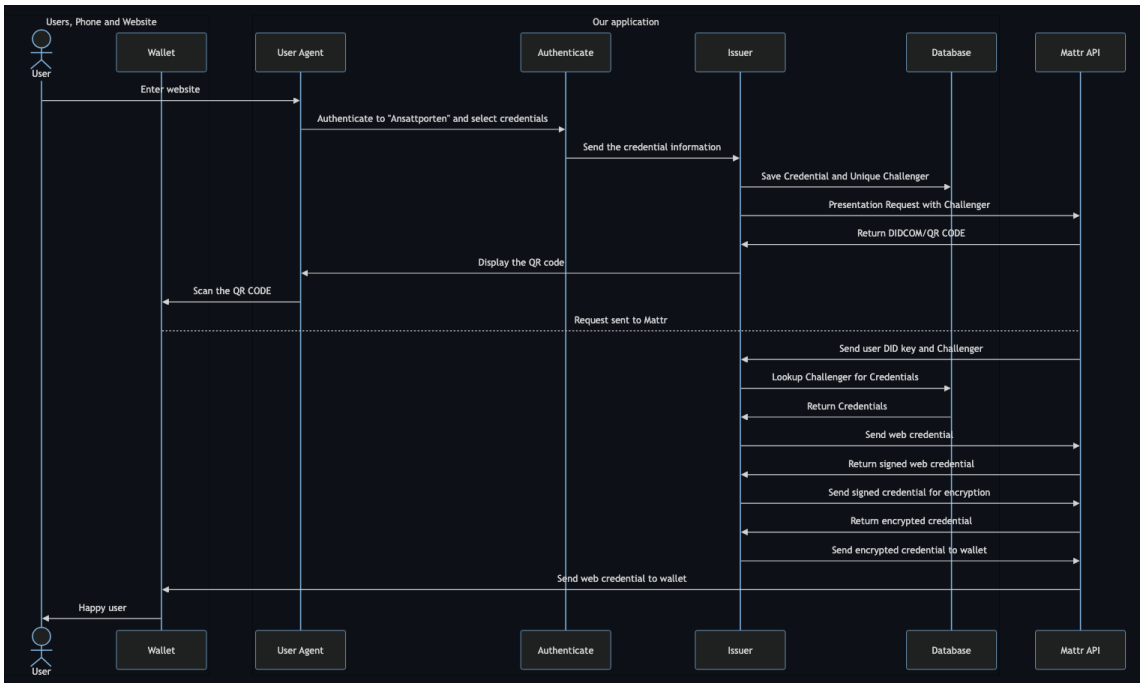
4.2 Vergemål

Vi håndterer en innlogging med id-porten, der man logger inn som verge, og får opplysning om hvem man er verge for. Vergehaver er en hardkodet verdi, som er lik for alle verger. Dette er laget for å bevise at det går an å lage ett bevis på at man er verge.

4.3 MATTR Issuer

I løpet av dette prosjektet har vi utviklet en issuer ved hjelp av Mattrs lommebok og deres API. Vår issuer gjør det mulig å sende rettigheter fra Ansattporten og vergebevis fra ID-porten. Etter innlogging mottar brukeren en QR-kode som skannes, hvoretter et digitalt kort blir lagt til i Mattr-lommeboken. Dette beviset kan deretter brukes i verifier-applikasjonen.

Vi har bestemt oss for å gå for en pre-autorise flyt for Mattr med en unik løsning. Brukeren logger seg inn med ansattporten eller id porten og får tilbake informasjon som skal bli sendt til Mattr lommeboken. Denne informasjonen blir lagra i en lokal database med en unik id. Deretter har vi en presentation requestsom blir brukt til å verifisere brukeren sin lommebok. Her får vi tilbake brukeren sin unike id og DID nøkkelen for lommeboken. Med den unike id-en henter vi informasjonen frå databasen, og bruker DID nøkkelen til å lage, kryptere og sende et bevis med informasjonen til lommeboken.



Figur 1: Sekvensdiagram for MATTR Issuer

4.3.1 Endepunkter for issuer

Funksjonaliteten til hvert endepunkt er beskrevet i Tabell 1.

Endepunkt	Funksjonalitet
/	Returnerer index.html, tjenestens forside der brukeren kan trykke på en knapp for å logge inn og sende en forespørsel til /login
/login	Gir brukeren to muligheter: Enten logge inn med ansattporten eller å logge inn med idporten. Beggge knappene vil ta brukeren videre til https://login.test.ansattporten.no/authorize/selector
/idporten_authentication	Etter brukeren er autentisert har de muligheit til å sende ut bevis ved å scanne en QR-kode, eller åpne en deeplink
/logout	Den vanlige siden frå springbot der en har muligheten til å logge seg ut
/logout/callback	Våres eigen utlogging side som tek en tilbake til index.html
/callback	Mattr API sender tilbake informasjon om brukeren sin lommebok som gjør det mulig å sende direkte bevis til burkaren, unngår at brukeren må skrive inn DID-key manuelt

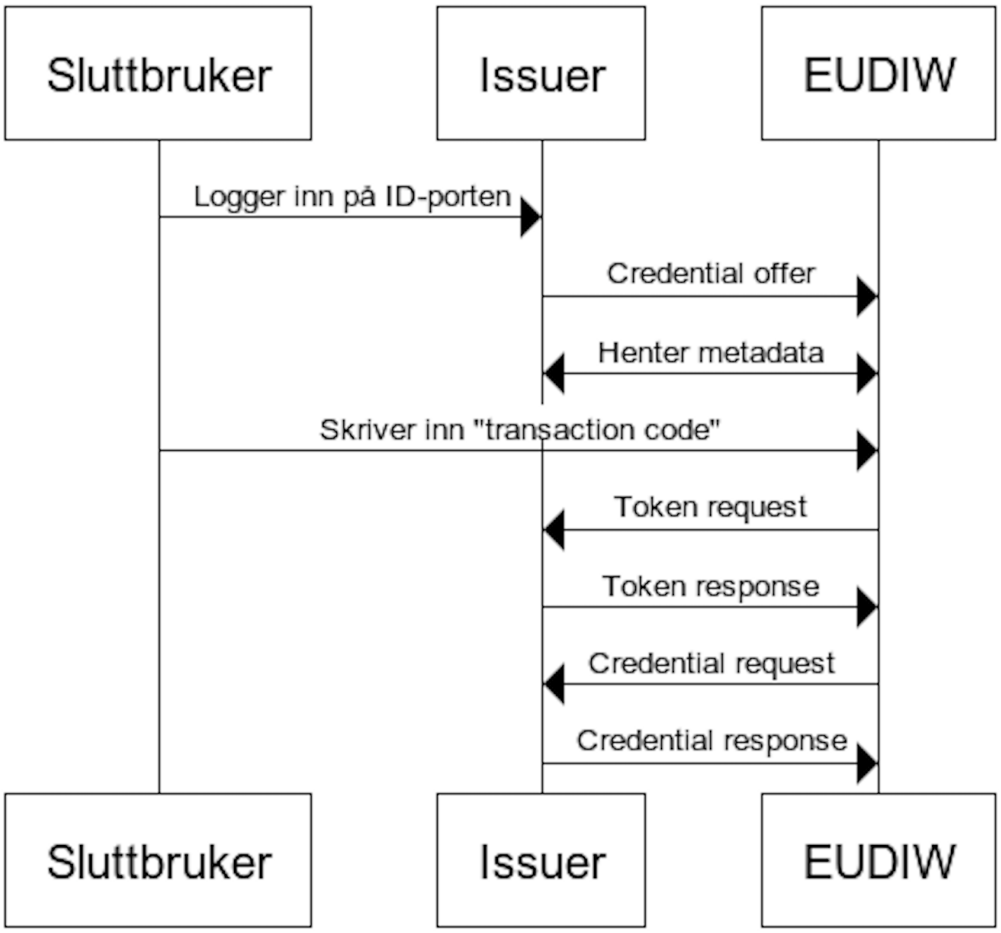
Tabell 1: Endepunkter for Issuer

4.4 EU Issuer

Etter at vi hadde implementert en Issuer ved bruk av Mattr, forsøkte vi å utvikle vår egen Issuer. I vår Issuer er det blitt tatt inspirasjon fra EU sin referanseimplementasjon, men EU sin kode er ikke brukt direkte. Begrunnelse for dette er forklart i disuksjonskapittelet. Issueren skal utstede bevis til EU Digital Identity Wallet (EUDIW), men all funksjonalitet ble ikke ferdig. I nåværende tilstand er det ikke mulig å legge til et bevis i EUDIW. For at denne implementasjonen skal fungere med EUDIW må det gjøres noen endringer rundt hvordan Issueren krypterer og signerer det digitale beviset. Dette problemet beskrives nærmere i FF-uture workdelen av README filen til prosjektet.

Selv om Issueren ikke fungerer til å utstede bevis enda, er det fortsatt mye som er gjort. Alle punktene i Pre-authorized flow i henhold til OpenID for Verifiable Credential Issuance (OID4VCI) draft 13 (punkt 3.5, Lodderstedt mfl., 2024) er implementert, men siste steg viker ikke. Her er en generell oversikt over hvordan Issueren bruker pre-authorized flow for å utstede bevis:

1. Hente vergemålsdata fra ID-porten: Data som blir hentet blir ikke brukt i selve beviset siden hardkodet verdier ble brukt under testing.
2. Lage credential offer: Dette er en forespørsel om å hente et bevis. Selve beviset ligger ikke her. For å hente beviset må man scanne en QR-kode med EUDIW. Sammen med QR-koden skal man også få en “transaction code“, men denne er hardkodet til å være 123456. Innbakt i QR-koden ligger en “Pre-authorized code“ som EUDIW bruker senere.
3. Metadataendepunkter: Etter QR-koden er scannet, vil EUDIW lese av metadataendepunktene “/.well-known/openid-credential-issuer“ og “/.well-known/openid-configuration“.
4. Sluttbrukeren må skrive inn “transaction code“ i EUDIW: Denne verdien er som sagt hardkodet til å være 123456.
5. EUDIW sender request til “/token“: Her er Pre-authorized code og “transaction code“ med. Tilbake får EUDIW en access token som blir brukt til å hente vergemålsbeviset.
6. EUDIW sender request til “/credential“: Access token som hentet fra “/token“, samt informasjon om hvilket bevis man vil ha blir sendt fra EUDIW til Issueren. Issueren sender vergemålsbeviset til EUDIW i COSE-format.



Figur 2: Sekvensdiagram for EU Issuer som følger OID4VCI

På steg 6. klarer EUDIW å motta vergemålsbeviset og dekode det, men det kommer opp en feilmelding. Videre informasjon om hvorfor Issueren ikke virker er rimelig tekninsk, og står derfor i README-filen til Issueren under Future work".

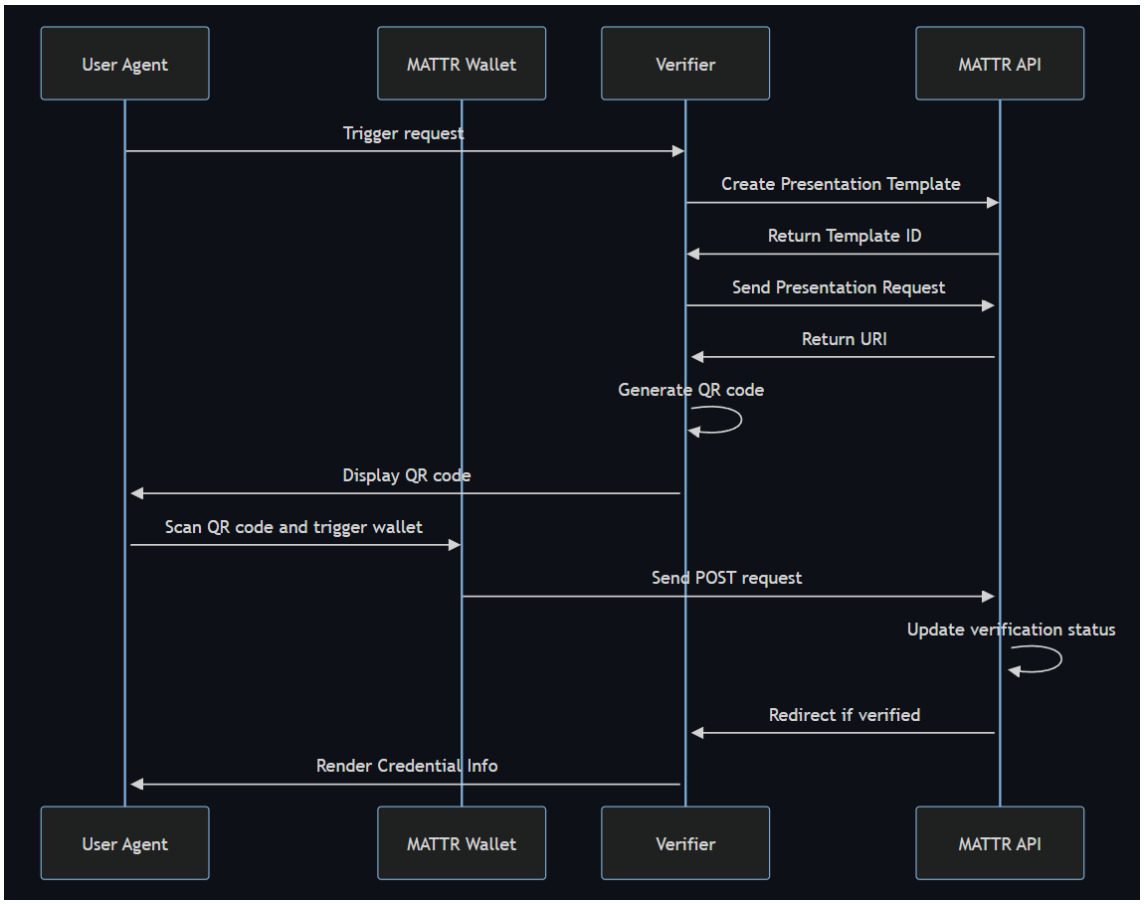
4.4.1 Endepunkter

Endepunkt	Funksjonalitet
/	Forside der man kan logge på idporten. Etter innligging får man en JWT som viser at man er innlogget. I fremtiden vil informasjon som er innbakt i JWT bli brukt i beviset som blir utstedt
/credential_offer	Genererer en QR-kode som kan bli lest av EUDIW for å få et digitalt bevis på lommeboken. Per nå får man feilmelding i løpet av utstedelsen av beviset
/.well-known/openid-credential-issuer	Metadata endepunkt som bør flyttes til ID-porten. For å bruke ID-porten sitt endepunkt må man skifte IDP på issuer. Les README for mer info
/.well-known/openid-configuration	Dette medatadaendepunktet skal ikke være på Issueren under produksjon, men heller på ID-porten. For å få EUDIW til å bruke ID-porten som authentication provider må man sette
/token	Henter token som blir brukt til å hente vergemålsbevis fra "/credential"
/credential	Her kan man få et vergemålsbevis (verifiable credential). For å få det må man ha en access token fra "/token"-endepunktet. Det digitale beviset blir kryptert og signert med COSE.

Tabell 2: Endepunkter for EU Issuer

4.5 MATTR Verifier

I løpet av prosjektet har vi også utviklet en Verifier som bruker MATTR sitt API for å verifisere bevis som vår MATTR Issuer utsteder til en brukers MATTR lommebok. Tross at Issuer og Verifier hovedsakelig består av backend, har vi laget en enkel frontend der brukeren kan navigere seg frem til tjenestens Presentation Request, i form av en QR kode. Når denne skannes vil tjenesten etterspørre et bevis i brukerens lommebok, og hvis brukeren har et gyldig bevis vil innholdet vises på tjenestens nettside. En mer detaljert beskrivelse av flyten kan sees i Figur 3.



Figur 3: Sekvensdiagram for MATTR Verifier

Vi fikk til slutt implementert hele flyten vi ser i Figur 3. Lenge oppsto det problemer når Mattr lommebok skulle sende POST-request med forespurt informasjon til Mattr API. Mattr sin lommebok ville ikke videresende bevisene vi hadde i lommeboken, og vi fikk da heller ikke verifisert disse. APIet returnerte da at beviset ikke har blitt verifisert til vår verifier. Grunnet treg responstid fra Mattr sitt utviklingssupportteam og nedprioritering av Mattr sitt API til fordel for EU sitt tok det en god stund før vi fikk ordnet opp dette problemet, men helt på tampen av prosjektet klaffet det.

4.5.1 Endepunkter for verifier

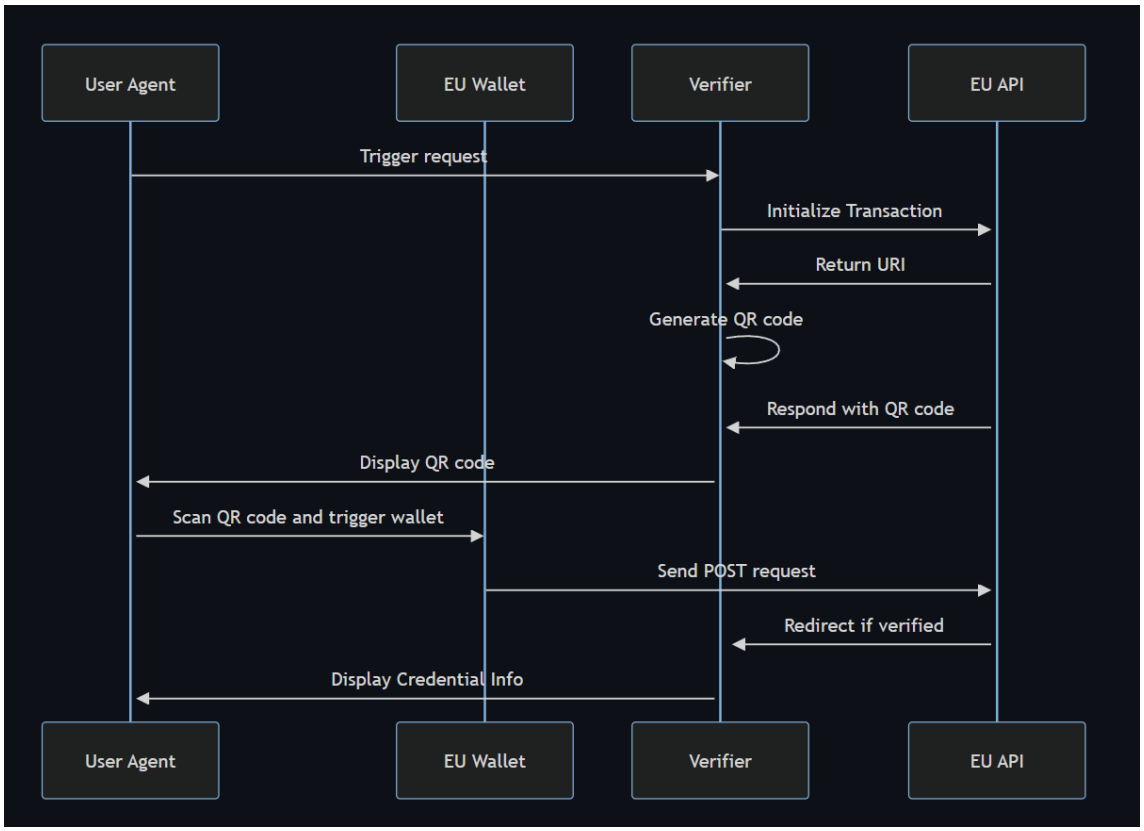
Vår Verifier har 5 endepunkter som håndteres av en Spring Boot Controller (Kleiven mfl., 2024b) basert på typen forespørsel den får tilsendt. 2 av endepuntkene funker som Setter/Getter for verifikasjonsstatusen til et bevis presentert av brukeren. De 3 andre brukes av kontrolleren til å videresende brukeren til ulike HTML-sider (Kleiven mfl., 2024a). Funksjonaliteten til hvert endepunkt er beskrevet i Tabell 3.

Endepunkt	Funksjonalitet
/	Returnerer index.html, tjenestens forside der brukeren kan trykke på en knapp for å generere en QR kode med en Presentation Request og sende en forespørsel til /qr-code
/qr-code	Viser den genererte QR koden og venter på at brukeren skanner den. qr-code.html har en javascript funksjon som konstant etterspør hasReceivedVP fra /verification-status og videresender brukeren hvis hasReceivedVP = true
/callback	Fungerer som en Setter for verifikasjonsstatus. Når endepuntket mottar en forespørsel settes hasReceivedVP til å være sant
/verification-status	Fungerer som en Getter for verifikasjonsstatus. Returnerer hasReceivedVP til /presentation-view
/presentation-view	Viser data hentet fra beviset til brukeren

Tabell 3: Endepunkter for Verifier

4.6 EU Verifier

Det har også blitt utviklet en Verifier som bruker EU sitt API, i motsetning til MATTR sitt. Frontend delen av vår Verifier er lik den som bruker MATTR, men en del av backenden har blitt endret for å tilfredstille flyten til EU sitt API. Forskjellen mellom de to flytene er hovedsakelig måten vår applikasjon registrerer responsen til lommeboken. EU sitt API håndterer og lagrer lommebokens respons, som gjorde av vi kunne etterspørre APIet kontinuerlig, for å sjekke om den hadde mottatt og verifisert brukerens bevis. Med MATTR måtte vi gjøre dette selv gjennom /callback og /verification-status. I tillegg til dette trenger man ikke lage et Presentation Template før man sender en Presentation Request når man bruker EU sitt API. Begge disse er kombinert i en Request. En mer detaljert beskrivelse av flyten til EU APIet kan sees i Figur 4.



Figur 4: Sekvensdiagram for EU verifier

Vi kom helt i mål med denne verifieren også og får verifisert beviset vi sender. Vi har riktig nok ikke satt opp APIet selv, men kaller på det som er oppe og går på EU sine servere og som deres Web Verifier-

demonettside også kaller på. I og med at vi ikke har hatt mulighet til å få utstedt bevis fra vår EU-issuer, har vi kun testet integrasjonen med eksempelbevis EU lommeboken selv oppretter.

4.6.1 Endepunkter for verifier

Endepunktene for EU Verifieren er nokså like endepunktene til MATTR Verifieren, men grunnet ulik flyt har det blitt fjernet noen endepunkter og lagt til andre. Ettersom at lommebokens respons lagres i EU sitt API trengte vi ikke lenger /callback og /verification status. Qr-code.html sender isteden Requests til verifier-backend.eudiw.dev/ui/presentations/ for å sjekke om brukeren har delt et gyldig bevis med lommeboken, for så å sende APIets respons til et av våre egne endepunkter, /cbor. Dette var nødvendig fordi beviset fra APIet returneres i CBOR format, så vi måtte lage et eget endepunkt som kunne dekode beviset for å lese verdiene til brukeren. Funksjonaliteten til hvert endepunkt er beskrevet i Tabell 4.

Endepunkt	Funksjonalitet
/	Returnerer index.html, tjenestens forside der brukeren kan trykke på en knapp for å generere en QR kode med en Presentation Request og sende en forespørsel til /qr-code
/qr-code	Viser den genererte QR koden og venter på at brukeren skanner den. qr-code.html har en javascript funksjon som konstant etterspør EU sin API for å sjekke om brukeren har sendt inn et gyldig bevis. Hvis gyldig sendes beviset til /cbor
/cbor	Dekoder beviset hentet fra EU sin API og lagrer det
/presentation-view	Henter beviset lagret av /cbor og viser data i beviset til brukeren

Tabell 4: Endepunkter for Verifier

5 Diskusjon

Dette kapittelet inneholder begrunnelse og valg av sentrale avgjørelser rundt det vi har laget.

5.1 Vergemålsdiskusjon

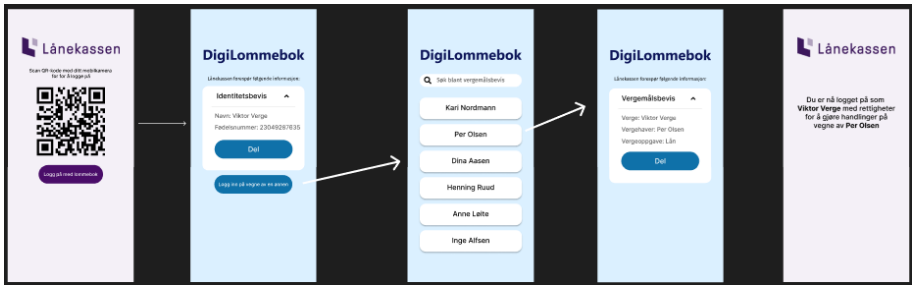
Basert på den utforskningen vi har gjort på MATTR og EU sine lommebokløsninger, har vi funnet at de ikke støtter mappeinndeling av forskjellige bevis i lommeboken. Dette vanskeliggjør våre visjoner av hvordan vi ønsker tjenesten til å fungere og se ut. Spesielt relatert til vergemål blir dette vanskelig, da eksempelvis advokater gjerne vil ha mange vergemål. Ønsket fra vår side er at lommeboken kan holde på alle bevisene på en slik måte at de ivaretar taushetsplikten, enkel sletting og oppretting av tilganger samtidig som den private lommeboken til verger som har mange vergemål ikke fylles opp av for mange dokumenter. På den ene siden vil det være ryddig å samle de forskjellige tilgangene i ett dokument i lommeboken, slik at vergen enkelt kan ha oversikten. På den andre siden er utfordringen med dette oppdatering av rettighetene inne i dokumentet.

Det er ønskelig at det kommer tydelig frem hvem som utfører handlinger og på vegne av hvem når man bruker en tjeneste. En løsning på dette er å følge anbefalning fra MinId-teamet, der de beskriver å gå fra en PID til to nye datafelt. De vil inneholde fødselsnummeret til verge, og ett eget felt for fødselsnummeret til vergehaver. Alternativt til dette kunne verge logget inn som vergehaver på vegne av vergehaver. Konsekvensen av dette blir at man ikke kan dokumentere hvem som har handlet på hvem sine vegne, eller om vergehaver har handlet på egne vegne. Vi mener det er mest trygt og oversiktlig å innføre to nye datafelter, og støtter MinId-teamet i deres vurderinger. Dermed har vi tatt utgangspunkt i to datafelter for alle flytene vi foreslår.

Da vi utforsket ulike metoder for å implementere vergemål i lommeboken, identifiserte vi tre forskjellige tilnærminger. Disse tilnærmingene vil bli presentert i detalj videre i rapporten.

5.1.1 Flyt 1

I det første alternativet skanner man en QR-kode for å logge inn på lommeboksen. Deretter kan man velge å logge inn på vegne av en annen, noe vi mener bør sikres ekstra med tofaktorautentisering, som passord og biometrisk godkjenning. Når man er logget inn som verge, får man oversikt over tilgjengelige vergemål og kan velge hvem man ønsker å utstede bevis for. Disse bevisene er forskjellige fra vanlige bevis, da de indikerer vergerollen og de nødvendige fullmaktene. Vi foreslår at innloggingsknappen for å logge inn på vegne av andre vises kun for verger. Dette gjør det enklere og mer brukervennlig for de som ikke har behov for denne funksjonen.



Figur 5: Alternativ flyt 1 - Vergemål

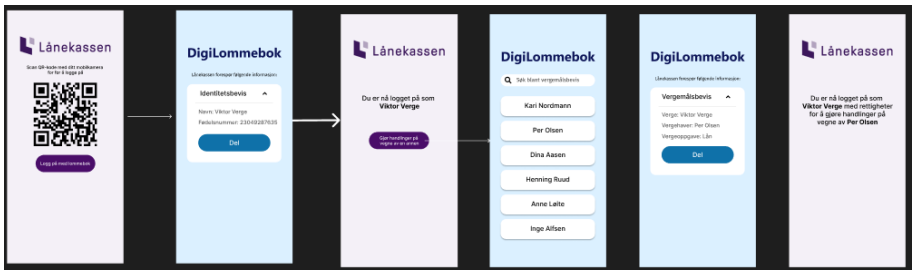
Flyt 1 har få trinn, noe som er positivt for brukeroplevelsen dersom verge har mange vergehavere. Ved å kunne samle handlingene man kan utføre på de respektive vergehaverene sine vegne og kunne dele beviset fra vergehaverens nivå, skiller man tydelig på rollene man tar på seg fra begynnelsen. For eksempelvis advokater som har mange vergehavere, kan dette være positivt for å skille mellom jobb og fritid. På den andre siden, må det være tydelig når man handler på vegne av andre. Det er mulig for brukerfeil ved at man trykker på feil person når man logger inn, og dermed handler på feil grunnlag. For å støtte denne

flyten må digitaliseringsdirektoratet utvikle sin egen lommebok dersom EU sin implementasjon ikke støtter mappestruktur senere i utviklingen. Søkefunksjonen bør implementeres.

5.1.2 Flyt 2

I det andre alternativet logger man først inn med sin egen brukerprofil, for eksempel på Lånekassen". Dersom man er verge, vil det da være en ekstra innloggingsknapp inne på tjenesten man er innlogget på med funksjonalitet for å la deg logge inn på vegne av en annen. Når man klikker på denne knappen, får man opp en liste over alle personer man er verge for. Her kan man velge hvilken person man ønsker å utføre handlinger for, og bruke vergebeviset til å gjennomføre nødvendige oppgaver.

Som i det første alternativet, er vergebeviset spesifikt og skiller seg fra vanlige identifikasjonsbevis. Kun verger har tilgang til muligheten for å bytte innlogging til "gjør handlinger på vegne av en annen".

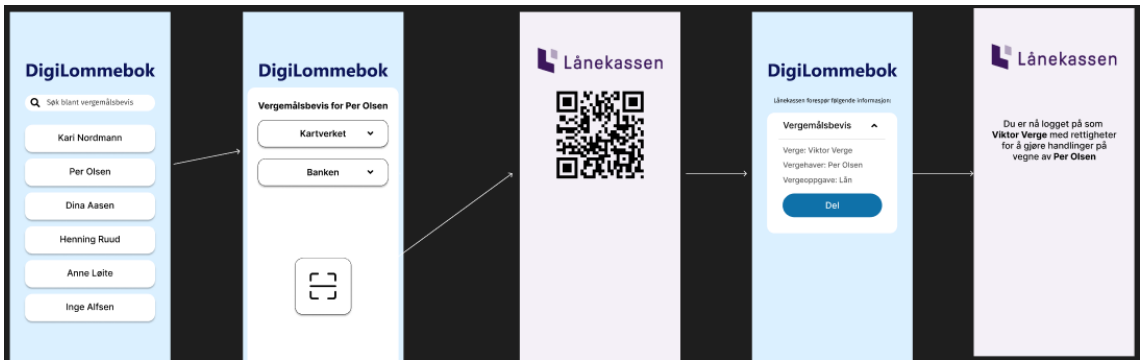


Figur 6: Alternativ flyt 2 - Vergemål

Flyt 2 vil være den enkleste for digitaliseringsdirektoratet å implementere, da denne flyten i stor grad håndterer systemene og dataene som de er i dag, med unntak av de to datafeltene. Denne flyten stiller i større grad krav til at tjenestene tilpasser seg denne flyten, og ikke at digitaliseringsdirektoratet tilpasser seg tjenestene. Tjenestene, som skattetaten, lånekassen etc, må lage nettsider som håndterer denne flyten. Dette krever at det settes en standard for hvor knappen for å handle på vegne av noen andre er, samt opplæring av verger på dette. Dette er også ett ekstra steg i forhold til flyt 1.

5.1.3 Flyt 3

I det tredje alternativet opprettes en egen mappe i 'Lommeboken' som gir en oversikt over vergemålene. Når man velger et vergemål, åpnes lommeboken som om man var en privatperson. Deretter scanner man en QR-kode, som gir muligheten til å dele den nødvendige informasjonen.



Figur 7: Alternativ flyt 3 - Vergemål

Alternativ tre forutsetter at digitaliseringsdirektoratet utvikler sin egen lommebok, som kan håndtere mappestruktur, samt qr-kode scanning på forskjellige nivåer med forskjellig identitetsgrunnlag. Det forutsetter også de to nye datafeltene.

Ulempen her er at man kan velge en person som ikke har de rette kortene i lommeboken, og dermed få en feilmelding om at kortet ikke finnes. Denne ulempen har man ikke i alternativ 1 og 2, fordi man der først scanner QR-koden og kun får opp de vergene som har den nødvendige informasjonen eller kortene som trengs.

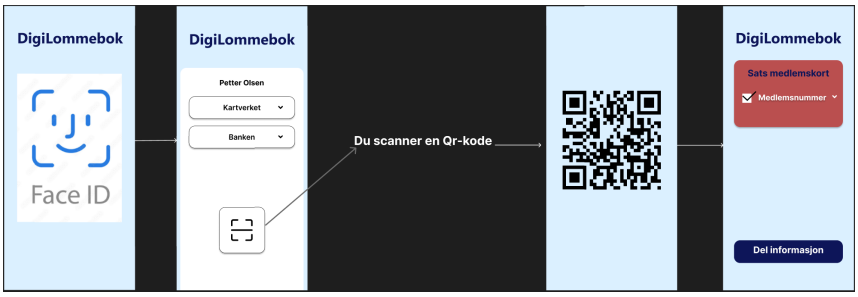
5.1.4 Flytkonklusjon

Utifra diskusjonen, lander vi på at argumentene taler for flyt en. Flyten separerer tydelig private handlinger fra vergemålshandlinger. Når det kommer til belastning av datasystemene til folkeregisteret, ser vi for oss at når man er registrert som verge så har man dette registrert på seg inne i lommeboka. Da kan man fra lommeboken velge om man skal utføre handlinger på vegne av seg selv, eller andre. Dermed unngår man mange unødvendige kall til folkeregisteret.

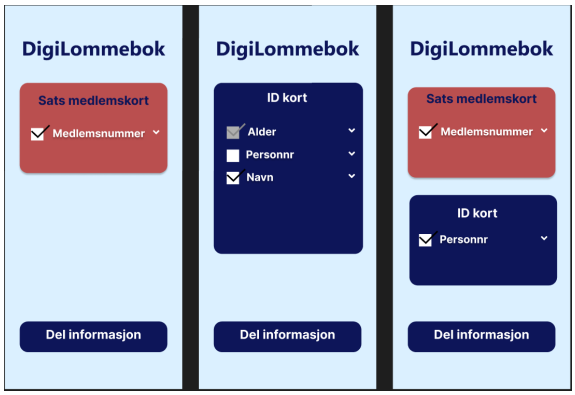
5.1.5 Deling av informasjon

For å sikre en trygg og oversiktlig deling av informasjon, foreslår vi å vise hvilket kort informasjonen hentes fra. Dette kan redusere risikoen for feilaktig deling av informasjon. For eksempel, hvis man skal dele informasjon fra et medlemskort til et treningssenter, vil man kunne oppdage en mulig feil hvis det samtidig deles data fra et annet kort. Dette kan fungere som en sikkerhetsmekanisme som forhindrer utilsiktet deling.

Videre kan det være flere kort med variabler som har samme navn, noe som kan skape forvirring. Ved å vise hvilket kort hver variabel tilhører, kan man lettere skille dem fra hverandre. Alternativt kan man hente frem attributter fra ulike kort og samle dem, men dette syns vi er en mindre gunstig løsning. Når attributter deler samme navn på tvers av kort, kan det øke risikoen for at man uforvarende deler informasjon man ikke ønsker å dele.



Figur 8: Flyt for deling av informasjon

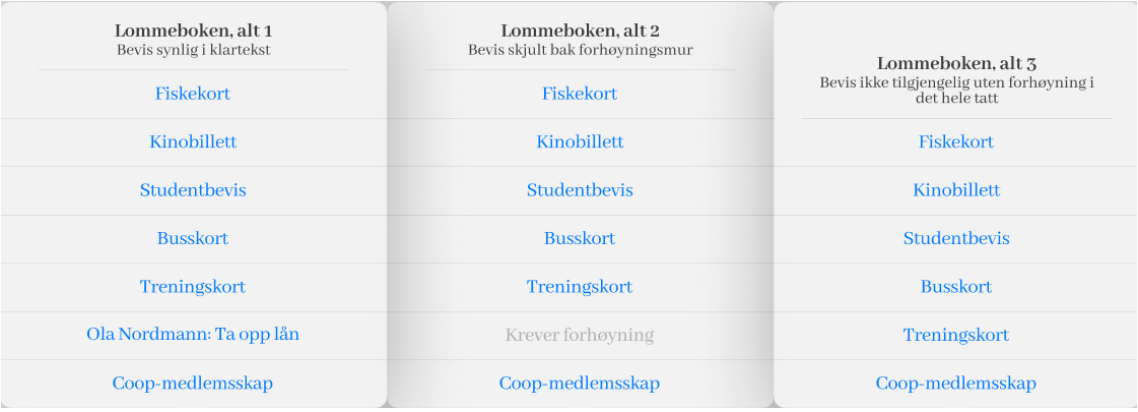


Figur 9: Viser kortene som deler informasjon

5.1.6 Autentisering

For å få tilgang til å handle på vegne av andre, burde det være skjerpede krav til autentisering. Vi mener at det ikke burde være nok å åpne appen dersom den kun trenger en pin-kode for å åpnes, for å se og bruke vergemålsdata. Vår vurdering er at dette burde kreve en forhøyning. Hva slag forhøyning dette burde være, overlater vi til ekspertene. Vi har identifisert forskjellige måter bevisene på vergemålshandlinger kan fremkomme i lommeboken:

Alt 1 går ut på å ha det i klartekst i lommeboken til verge. Alt 2 og 3 har beviset bak en forhøyningsmur. Alternativ to viser att det er ett bevis i lommeboken som krever forhøyning, mens alternativ tre ikke viser att det ligger ett bevis som krever forhøyning der i det hele tatt, det vil kun bli synlig dersom verge forhøyner tilgangene sine. Vi mener alternativ en er ett dårlig alternativ, da dette ikke ivaretar taushetsplikten. Uavhengig av at man ikke kan bruke beviset uten forhøyning, vil dette vise navnet på vergehaver i den private lommeboka til verge. Dersom man er verge for mange vergehavere, og alle bevisene skal synes som krever forhøyning", tar dette mye plass. På den andre siden, så kan det være forvirrende for verge å lete etter vergemålsbevisene når de ligger som "usynligebevis i lommeboken.



Figur 10: Forhøyning og synlighet

Vi velger å anbefale alternativ tre, da vi mener dette ivaretar taushetsplikten best, samt at den private lommeboken til verge ikke oppleves som overfylt dersom man har mange vergemål.

5.2 Erfaringer med Issuer

5.2.1 EUs referanseimplementasjoner vs. Mattr

Fra resultat har vi laget Proof of Concept (PoC) av både issuer og verifier ved å bruke Mattr sine API-er og en annen PoC som har brukt EU sin referanseimplementasjon som utgangspunkt. Det har imidlertid ikke gått helt feilfritt å jobbe med EU sine referanseimplementasjoner.

Mangel på akseptabel dokumentasjon i EU sin referansekode gjorde det vanskelig for oss å forstå oss på hvordan den fungerte. Vi gikk derfor over til å bruke Mattr sine APIer, som viste seg å være mer stabil og lettere å bruke. Dokumentasjonen til Mattr er også langt bedre enn EU sin dokumentasjon, og mange av stegene for Issuance og Verification er abstrahert bort til API-kall til deres tjenester. På en annen siden har det heller ikke vært uten problemer å jobbe med Mattr. Mattr har et OID4VCI API, men denne fikk vi ikke til å fungere med ID-porten eller ansattporten. Derfor måtte en alternativ løsning til for å utstede bevis, som er beskrevet i kapittel 4.3.

Etter at vi implementere en Verifier og Issuer med Mattr, gikk vi tilbake til å lage Issuer og Verifier til EUDIW. Selvom vi klarte å lage en Verifier med EU sin API gjorde mangel på god dokumentasjon at vi ikke fikk referanseimplementasjonene av Issuer til å fungere. Derfor lagde vi vår egen implementasjon av Issuer. Issuer var mer komplisert å implementere og har derfor litt problemer. For at Issuer skal virke, må

man ha en “device_key“ som skal bli brukt til å signere beviset i COSE-format, men vi fant ikke ut hvordan man får tak i EUDIW sin “device_key“. “device_key“ er en offentlig nøkkel som EUDIW har.

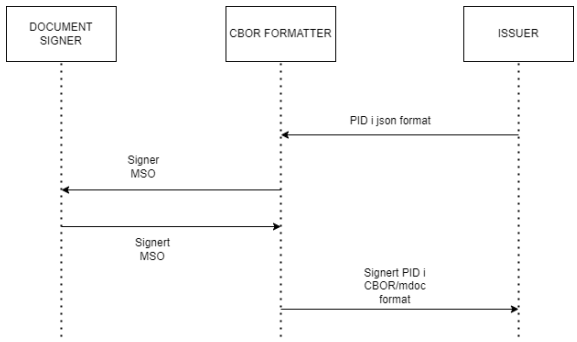
Selv om EU lommebok sin referanseimplementasjon har potensiale, er det tydelig at den trenger videreutvikling og forbedringer før den kan brukes på en mer bred skala. Bedre dokumentasjon hadde også gjort opplevelsen langt bedre for utviklere.

5.2.2 Ansattporten data

Dataen fra ansattporten ble presentert i form av en JWT med informasjon om tilganger knyttet til innlogget person. Det var mulig å velge flere bedrifter samtidig, og man fikk da flere bedrifter/tilganger på en token. Dette har vi håndtert i koden ved å dele opp de forskjellige bedriftene/tilgangene med deres tilhørende rettigheter, slik at de bevisene som blir utstedt, ikke havner på samme utstedningsbevis. Eksempelvis ønsket vi ikke at en leges helsepersonelltilgang skulle ende opp på samme kort som samme persons enkeltmannsforetak som trombonesolist. Vi ønsket løs kobling mellom de forskjellige bevisene, samt at det skulle være enkelt å trekke tilbake bevisene dersom det var behov for det, for eksempel om bedriften fikk en ny daglig leder. Detter er også viktig utenfor ansattporten, da det er mange bevis som skal være mulig å trekkes tilbake, slik som førerkortet.

5.2.3 EU mDOC CBOR formatter

For at vår implmeentasjon av EU Issuer skal kunne legge inn bevis i EUDIW, måtte utstedte dokumenter være i base64-url encoded CBOR bytes, samt det må være kryptert og signert med COSE. Vi fant et repository på EU sin hovedside som håndterer dette med å både signere og formattere meldingen. Eu sitt program inneholder en signereingsdel (Document Signer) og en formatteringsdel (CBOR formatter). Repositoriet var ikke spesiselt godt dokumentert, og det var utfordrende å få det til å fungere slik det var ment. Vi prøvde å komme i kontakt med eier av repositoriet uten suksess. Til slutt tok vi en egen kopi (fork) av repoet, og endret på koden for å fikse slik at det fungerte for oss. Vi klarte å signere og kryptere til slutt, men feil public key (“device_key“) er brukt. Dette er dokumentert i README til vår egen issuer. Her er ett flyt-bilde av EU sitt signeringsprogram.



Figur 11: Kommunikasjon mellom vår issuer og CBOR formatter

5.3 Erfaringer med Verifier

I løpet av prosjektperioden har vi jobbet parallelt med både Issuer og Verifier. Inntrykket vi har fått av dette er at selv om Verifieren ikke er enkel, er den enklere enn Issueren. Dokumentasjonen av EU sin Verifier referanseimplementasjon er bedre, i hvert fall i forhold til bruk av Verifier APIet, ikke nødvendigvis i forhold til eget oppsett av APIet. I tillegg var EU sin Verifier API lettere å bruke enn Issuer APIet, som vi ikke fikk til å fungere, og MATTR APIet, der vi slet med å hente MATTR lommeboken sin respons.

Verifierene vi har utviklet støtter seg kraftig på enten MATTR eller EU sitt API. Uten disse hadde det trolig ikke vært like lett å utvikle en Verifier. Vi har også prøvd å selv sette opp EU sitt API gjennom fly.io, men dette ble vanskelig av 2 grunner. Først og fremst, selv om det var dokumentasjon på EU sin Verifier, var det manglende dokumentasjon på hvordan man kunne sette opp selve APIet. Videre tydet det også på at EU

ønsket at både Verifier API og Verifieren skulle kjøre på samme addresse slik at man lettere kunne sende Requests fram og tilbake. Vi klarte ikke å gjøre dette gjennom verken fly.io eller Render.com. Da vi prøvde å sette disse opp på hver sin addresse sendte de kun spørringer til sine egne endepunkter.

EU APIet i seg selv derimot var lettere å bruke enn MATTR sitt. Når vi ikke trengte å sette opp APIet, men heller kunne bruke den som EU hadde, var det nokså lett å lage vår Verifier. I tillegg hjalp det at vi hadde laget en Verifier med MATTR tidligere, da disse hadde en nokså lik flyt. Ettersom at flyten er ganske lik i de to APIene (Figur 2 og 4) regner vi med at dette er en nokså ideell flyt, som EU kommer til å fortsette med. Dermed vil vår implementasjon av EU Verifier trolig være relevant en stund fremover.

Når man henter ut beviset som brukeren har sendt til EU Verifier APIet blir dette returnert som CBOR. Dette skjer hvis tokentypen til Transaction Initialization er ”vp_token”. Så vidt vi har erfart er det ikke mulig å sette tokentypen til ”id_token”, som hadde vært enklere da slike bevis returneres som JSON isteden for CBOR. For å dekode CBOR beviset måtte vi først dekode det som base64url og så CBOR, for så å dekode dataene i beviset som base64 og CBOR. Dette tok litt tid å finne ut av, samt at det føltes litt for komplisert ut. EU bruker som sagt begge måtene, men vi klarte ikke å få JSON formatet til å funke.

6 Konklusjon

Dette har vært en spennende oppgave å arbeide med gjennom sommeren. Å få delta i utviklingen av en digital lommebok har gitt oss verdifull innsikt i både tekniske utfordringer og muligheter. Til tross for noen utfordringer underveis, spesielt knyttet til bruken av EU lommebok sin referanseimplementasjon, er vi totalt sett fornøyde med resultatet og erfaringene vi har opparbeidet oss.

6.1 Oppsummering

Gjennom denne rapporten har vi utforsket prosessen med å implementere en issuer og en verifier ved hjelp av Java og Spring Boot. Vi har sett på hvordan viktige prinsipper for design ble anvendt for å skape en robust og brukervennlig applikasjon. Utfordringene vi støtte på, særlig relatert til tilstanden til EU lommebok sin referanseimplementasjon, ledet oss til å benytte en alternativ løsning fra Mattr, som viste seg å være mer stabil og egnet for vårt prosjekt.

6.2 Fremtidige anbefalinger

6.2.1 Optimalisering og videre utvikling

For videre utvikling fra dette prosjektet ville vi anbefalt å ta hensyn til at EU lommebok sin referanseimplementasjon fortsatt er under utvikling, men at den kan ha potensiale for å være robust fremover. Det kan også være nyttig å utforske muligheter for integrasjon med andre digitale tjenester, med tanke på utvidelse av funksjonalitet og bruksområdet til applikasjonen.

Vi anbefaler å fokusere på å optimalisere brukeropplevelsen ved å gjennomføre ytterlige testinger og tilpasninger til ulike brukerscenarier og enheter. Det kan også vært nyttig å utforske muligheter for integrasjon med andre digitale tjenester for å utvide funksjonaliteten og bruksområdet til applikasjonen. Vi foreslår å implementere en innebygd QR-kode sjekker, som skanner QR-koden før den utfører forespørsler basert på innholdet. Den kan sjekke om koden er for en tjeneste som er relatert til lommeboken.

6.2.2 Tilgjengelighet for Blinde og Svaksynte

Dette er et område hvor enkle tilpasninger kan øke tilgjengeligheten betydelig. Applikasjonen bør fokusere på å forbedre tilgjengeligheten for blinde og svaksynte gjennom implementering av ARIA-labels for bedre beskrivelser og knapper, bevisst bruk av farger for å sende tydelige signaler, og bruk av lyd- og vibrasjonssignaler for veiledning ved QR-kode skanning. Integrering av tekst-til-tale teknologi kan gi tilbakemelding i form av lyd på QR-innholdet. Full kompatibilitet med skjermlesere som VoiceOver og TalkBack kan også viktig for å sikre en god brukeropplevelse. Testing og samarbeid med blinde og svaksynte er viktig for å oppnå en inkluderende løsning. Målrettende og kreavtive løsninger vil være nødvendig for å realisere disse målene, eller lignende mål rundt tilgjengelighet.

6.2.3 Anbefalte tiltak for videre utvikling

Vi ønsker å anbefale digitaliseringsdirektoratet å se videre på EU sin lommebok, da vi opplever at den er brukbar for videre utvikling. Vi ser også at dersom noen andre skulle tilbydd tilsvarende lommebokløsninger, ville det vært naturlig å se til digitaliseringsdirektoratet.

Vi har samarbeidet med Kantega og MATTR, og opplever at det har vært til hjelp. Det er mange tjenester man kan se på for inspirasjon til både lommebokløsninger, issuer og verifier. Det kan være en mulighet å leie inn konsulenttjenester fra en av de relevante aktørene.

Vi har hatt dårlig erfaring med EU sin referanseimplementasjon av issuer slik den er nå. Dette kan selvfølgelig endre seg med tiden, men slik tilstanden er nå så anbefaler vi digitaliseringsdirektoratet å skrive sin egen.

Videre ville vi sett nærmere på hvordan vi kan forbedre tilgjengeligheten for blinde og svaksynte, noe som har stort potensial for videreutvikling og forbedring rundt universell utforming.

Vi anbefaler digitaliseringsdirektoratet å se videre på hva som kan forhøyne rettighetene til lommebokbrukere. Om dette blir tofaktor, kodebrikke eller annet mener vi ekspertene i digitaliseringsdirektoratet er bedre rustet en oss til å bestemme.

6.3 Ting som har fungert bra

Under prosjektet har vi hatt gode erfaringer med Verifieren. Sammenlignet med Issueren har den vert enklere å håndtere, grunnet bedre dokumentasjon, spesielt ved bruk av Verifier APIet. EU sin Verifier API var betydelig enklere å bruke enn Issuer- og MATTR APIene. Bruken av EU eller MATTR APIet har gjort utviklingen av Verifieren mye enklere.

Referanser

Altinn. (2017, 4. desember). *What is Altinn?* [Hentet 16. juli 2024]. https://info.altinn.no/en/about-altinn/what-is-altinn

auth0. (2024). *OpenID Connect Protocol* [Hentet 16. juli 2024]. https://auth0.com/docs/authenticate/protocols/openid-connect-protocol

Binningsbø, J. (2024). *Løysingsarkitektur Innlogging for verger*. https://digdir.atlassian.net/wiki/spaces/~85220912/pages/2676686856/L+ysingsarkitektur+Innlogging+for+verger

Bremer, A. (2024 juni). Introduction to Auth2 and OpenID Connect [Hentet 15. juli 2024]. Fra_Digdir

Cloudfare. (2024). *What is a network protocol?* [Hentet 16. juli 2024]. https://www.cloudflare.com/learning/network-layer/what-is-a-protocol

Crane, C. (2020, 10. august). *What Is a Certificate Authority (CA) and What Does It Do?* [Hentet 15. juli 2024]. https://www.thesslstore.com/blog/what-is-a-certificate-authority-ca-and-what-do-they-do

Digdir. (2024a). *Farger* [Hentet 24. juli 2024]. https://profilveileder.digdir.no/visuell-profil/farger/109

Digdir. (2024b). *Integrasjonsguide* [Hentet 16. juli 2024]. https://docs.digdir.no/docs/idporten/oidc/ansattporten_guide

eidDifi. (2024). *ID-Porten* [Hentet 16. juli 2024]. https://eid.difi.no/nb/id-porten

Goodwin, M. (2024, 9. april). *What is an Application Programming Interface (API)?* [Hentet 16. juli 2024]. https://www.ibm.com/topics/api

IDManagement. (2024). *Public Key Infrastructure 101* [Hentet 15. juli 2024]. https://www.idmanagement.gov/university/pki

Kleiven, O. F., Friis, K. S., Eikeland, S., & Løwer, M. (2024a). *Github - Templates* [Hentet 06. august 2024]. https://github.com/felleslosninger/dc24-wallet-verifier/tree/main/src/main/resources/templates

Kleiven, O. F., Friis, K. S., Eikeland, S., & Løwer, M. (2024b). *Github - Verifier Controller* [Hentet 06. august 2024]. https://github.com/felleslosninger/dc24-wallet-verifier/blob/main/src/main/java/no/idporten/ansattporten_integration/web/VerifierController.java

Lodderstedt, T., Yasuda, K., & Looker, T. (2024). *OpenID for Verifiable Credential Issuance - draft 13* (tekn. rapp.). OpenID. https://openid.net/specs/openid-4-verifiable-credential-issuance-1_0.html

Marco, G. D. (2024 juli). *pyMDOC-CBOR* (tekn. rapp.). EU. github. https://github.com/eu-digital-identity-wallet/pyMDOC-CBOR

Marco, G. D., Rose, P. D., Alessio, M., Laiso, S., & Saitto, N. (2024 august). *eudi-wallet-it-python* (repository). Italian government. github. https://github.com/italia/eudi-wallet-it-python

Pereira, L., Miranda, J., Giakkoupis, M., & Kanellopoulos, V. (2024 juli). *eudi-srv-web-issuing-eudiw-py* (tekn. rapp.). EU. github. https://github.com/eu-digital-identity-wallet/eudi-srv-web-issuing-eudiw-py/pull/37/files

Shaad, J., & Cellars, A. (2024 juli). *CBOR Object Signing and Encryption (COSE)* (tekn. rapp.) (Hentet 05. juli 2024). RFC Editor. https://datatracker.ietf.org/doc/html/rfc8152#section-1.1

Sivilrettsforvaltningen. (2024). *Om vergemålsmyndighetene* [Hentet 24. juli 2024]. https://www.vergemal.no/om-vergemalsmyndighetene

Sporny, M., Longley, D., Sabadello, M., Reed, D., Steele, O., & Allen, C. (2022, 19. juni). *Decentralized Identifiers (DIDs) v1.0* [Hentet 15. juli 2024]. https://www.w3.org/TR/did-core

Vedlegg

Eksempel på vedlegg:

- Issueboard